Lumi Reading · Security & Privacy Evidence

HR1 / HR2 / HR3

HR Security Pack

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

HR1/2/3 EVIDENCED 2026-07-24 · SIGNATURE PENDING

ST4S items: HR1 (personnel screening), HR2 (security awareness training), HR3 (offboarding / access revocation) **Related:** A7 (access review/revocation), A10 (device standard), child-safety obligations **Version:** 1.0 · **Date:** 2026-07-24 **Status:** HR1 (WWCC held) + HR2 (training done) + HR3 (dry-run done) evidenced 2026-07-24 · pending signature

1. Purpose and scope

This pack defines the human-side security controls for Lumi Reading: who is screened before they can touch student data, what security awareness training everyone completes, and how access is removed when someone leaves or a role ends.

Scope: every person with any access to Lumi student data or the systems that hold it — today that is the single director; on engagement, any contractor, adviser, or support person. The three sections map one-to-one to ST4S HR1/HR2/HR3 and share one driving artefact — the **Access Register** (`ACCESS_REGISTER_TEMPLATE.md`) — which is the authoritative list of who has access to what and therefore what must be screened, trained, and revoked.

Truthfulness note. This pack states the **standard** and the records required to evidence it. It does **not** assert that a specific check, a specific training completion, or a specific revocation has occurred — those are Nic's real-world actions and become evidence only once done and dated (see §5). No check reference numbers, personal identifiers, or other PII appear in this document or in git; only the *outcome* (e.g. "current WWCC held — verified") is recorded in the evidence pack, with the underlying detail kept in a restricted HR file.

2. Section A — Employment / engagement screening standard (HR1)

2.1 Standard

Before **any** person is given access to Lumi student data (the app data, the `lumi-ninc-au` production project, the portals, or the support/admin mailboxes), they must hold:

- a **current Working With Children Check (WWCC)** valid for the relevant jurisdiction (Lumi operates with Australian schools; the WWCC is the primary, mandatory screening for anyone who can access children's data); and
- **optionally, a National Police Check (NPC)** where warranted by the role or requested by a partner school as an additional assurance.

The check must be **verified as current** — sighted and confirmed against the issuing authority, not merely asserted — before access is granted, and re-verified on expiry.

2.2 What is recorded, and where

Field	Stored where
Check **type** (WWCC / NPC)	Restricted HR file (not git)
Reference / card number	**Restricted HR file only** — never git, never this pack
Issue date, **expiry date**	Restricted HR file (expiry drives re-verification)
Outcome ("current — verified", verifier, date verified)	Evidence pack (this is the only field surfaced for ST4S)

The evidence pack contains only the outcome line. The underlying document, card number, and personal details are held in a restricted HR file (e.g. password manager / encrypted store), consistent with data-minimisation and with §5 of the device standard (no PII in the repo).

Current outcome (HR1): Nic holds a **current WWCC — verified 2026-07-24**. The type/reference/date/expiry are stored in Nic's off-git encrypted store and backed up outside Git.

2.3 Cadence

- **Before access:** no student-data access is granted until a current WWCC is verified (this is a hard gate in onboarding, §4).
- **On expiry:** the expiry date in the restricted HR file drives re-verification; a lapsed check means access is suspended until renewed.
- **Annual reconciliation:** at the annual access review, confirm every person in the Access Register still holds a current check.

---

3. Section B — Security awareness training program (HR2)

3.1 Standard

Everyone with access completes **security awareness training at least annually** (and at onboarding, before or immediately on being granted access). Training covers the ST4S content areas:

1. **Phishing & social engineering** — recognising and reporting suspicious email/SMS/calls; that Lumi will never ask for a password/OTP; verifying unexpected requests out of band.
2. **Passwords & MFA** — the Lumi credential standard (14+ / complexity, per A2), a password manager, unique passwords per system, and mandatory MFA on privileged accounts (per `ACCESS_CONTROL_POLICY.md` §6).
3. **Data handling & classification** — what counts as student PII, minimisation, Australian data-residency (`lumi-ninc-au`, `australia-southeast1`), and not moving student data out of approved systems.
4. **Incident reporting** — how and when to raise a suspected incident, and the response path (`EV9_INCIDENT_RESPONSE_PLAN.md`); report early, don't sit on it.
5. **Device security** — the endpoint standard (`DEVICE_STANDARD.md`): lock screen, encryption, updates, no shared accounts, lost-device response.
6. **Privacy & child-safety obligations** — child-safety duty of care, WWCC obligations, the privacy policy and APP obligations, and appropriate handling of children's information.
7. **Acceptable use** — approved-systems-only, no credentials in code/tickets, no shadow tools handling student data, and the branch→PR→review workflow as a security control (peer review before merge).

3.2 Delivery and records

- Training may be delivered via a reputable external module (e.g. a security awareness provider) and/or an internal walkthrough of the ST4S content areas above and these policies.
- **Completion is recorded and dated**: name, date completed, module/version, and topics covered. The dated completion record is the HR2 evidence.
- New joiners complete it at onboarding (§4); everyone re-completes annually.

3.3 Records template

Person (named)	Role	Module / content version	Date completed	Next due	Evidence (certificate / attestation ref)
Nicholas Plevritis (Director)	Director / all access	ST4S content areas 1–7 + policy walkthrough	**2026-07-24**	2027-07-24	`SECURITY_TRAINING_RECORD.md` — self-directed session (completed)

4. Section C — Offboarding / access-revocation checklist (HR3)

4.1 Standard

When a person leaves, a role ends, or a device/engagement is terminated, **all system access is revoked same-day** — and **immediately** where the departure is involuntary or there is any suspicion of malicious intent. Revocation is driven by that person's row(s) in the **Access Register** so nothing is missed.

4.2 Trigger and timing

Situation	Timing
Planned departure / engagement end	**Same business day** as the last day
Involuntary / for-cause / suspected malicious	**Immediately** — before or at notification; treat as a potential incident (`EV9_INCIDENT_RESPONSE_PLAN.md`)
Role change (reduced scope)	Same-day downgrade to least privilege for the new role

4.3 Checklist (run against the leaver's Access Register rows)

For each system the person appears against in the Access Register, revoke and record the date/time:

- [ ] **Identity / SSO** — disable the Google/Workspace or primary identity; end active sessions.
- [ ] **GCP / Firebase (`lumi-ninc-au`)** — remove all IAM role bindings; confirm no lingering service-account impersonation or key access.
- [ ] **GitHub** — remove from the org/repo; revoke personal access tokens, SSH keys, and any OIDC/CI trust tied to the person.
- [ ] **Apple Developer** — remove from the team; revoke signing access.
- [ ] **Google Play Console** — remove user and permissions.
- [ ] **Portals** — remove/disable super-admin (`/superAdmins/{uid}`) and any school-admin/teacher membership; per `ACCESS_CONTROL_POLICY.md` §3.3 and the server-op offboarding path, this revokes app-

level access too.

- [ ] **Support / admin mailboxes** — remove delegated access to support/admin/demo/review mailboxes; reset shared-mailbox credentials if the person knew them.
- [ ] **Domain registrar & DNS** — remove account access; rotate credentials if shared.
- [ ] **Cloudflare** (status worker / edge) — remove account access; rotate API tokens the person held.
- [ ] **Password manager** — revoke vault access; **rotate every shared secret** the person could have seen (this is the critical step for a for-cause exit).
- [ ] **Devices** — collect or remotely wipe any Lumi device (`DEVICE_STANDARD.md` §5); retire the device-register row.
- [ ] **Access Register** — mark every row revoked with date/time and who performed it; the register is the completed evidence.

4.4 Verification

After revocation, confirm the person can no longer authenticate to any system (spot-check the highest-risk: GCP/Firebase, GitHub, super-admin portal), and that every shared secret they could have known has been rotated. Record the verification date. A for-cause exit additionally runs the incident-response review to check for any action taken before revocation.

4.5 First offboarding dry-run (tabletop) — 2026-07-24

Lumi is a single-operator estate with no departure yet, so HR3 was exercised as a **tabletop dry-run** against the populated Access Register (`ACCESS_REGISTER_TEMPLATE.md` §4) on **2026-07-24**. For a hypothetical leaver holding the director's full access profile, every system in the register was mapped to a §4.3 revocation step and its method/owner confirmed. **No access was actually revoked** (there is no real departure) — the exercise validates that the checklist is complete and that no system is missed.

Register system	§4.3 step	Revocation method	Covered?
GCP / Firebase `lumi-ninc-au`	Identity/SSO + GCP	Remove all IAM bindings; end sessions; confirm no SA impersonation/keys	✅
GitHub	GitHub	Remove from org/repo; revoke PATs, SSH keys, OIDC/CI trust	✅
Apple Developer	Apple Dev	Remove from team; revoke signing	✅
Google Play	Google Play	Remove user + permissions	✅
School + super-admin portals	Portals	Remove `/superAdmins/{uid}` + memberships (revokes app-level access)	✅
Mailboxes (Google Workspace)	Mailboxes	Remove delegated access; reset shared credentials	✅
Domain registrar	Registrar	Remove account access; rotate credentials if shared	✅
Cloudflare	Cloudflare	Remove account access; rotate API tokens	✅
Password manager	Password mgr	Revoke vault; **rotate every shared secret** (critical for a for-cause exit)	✅
Devices	Devices	Collect / remote-wipe; retire device-register row	✅

Findings. The §4.3 checklist covers **100%** of the systems in the Access Register — no system is missed; the revocation method and owner are known for each; shared-secret rotation is correctly flagged as the critical for-cause step. The offboarding process is **validated and ready**. The first real departure will produce the completed §4.3 run with actual dated revocations. **Next dry-run:** annually, or immediately before the first hire/contractor engagement.

Performed by: Nicholas Plevritis · Date: 2026-07-24.

---

5. Supporting evidence index

Control	Evidence (owned by Nic)
Screening standard (HR1)	**Current WWCC held — verified 2026-07-24**; type/ref/date/expiry kept in Nic's off-git encrypted store; outcome line only in this pack
Awareness training (HR2)	`SECURITY_TRAINING_RECORD.md` — completed **2026-07-24** (§3.3); next due 2027-07-24
Offboarding (HR3)	Process (§4.3) + **first tabletop dry-run 2026-07-24 (§4.5)** covering 100% of register systems; first real run on the first departure
Access register (driver for HR1 & HR3)	`ACCESS_REGISTER_TEMPLATE.md` — **populated + first review 2026-07-24**
Server-side portal/app revocation	`ACCESS_CONTROL_POLICY.md` §3.3, §8 (super-admin + membership offboarding)
Device collection / wipe	`DEVICE_STANDARD.md` §5
Incident path for for-cause exits	`EV9_INCIDENT_RESPONSE_PLAN.md`

6. Status — HR1 / HR2 / HR3 (updated 2026-07-24)

- **HR1 (screening) — MET.** Nic **holds a current WWCC**, verified **2026-07-24**. Its type/reference/date/expiry are kept in Nic's **off-git encrypted store** (backed up off Git); only the outcome line appears here. Repeat for any contractor/adviser who later gains access to student data.
- **HR2 (training) — DONE.** Annual security awareness training completed **2026-07-24**; dated record `SECURITY_TRAINING_RECORD.md` (§3.3). Next due **2027-07-24**.
- **HR3 (offboarding) — PROCESS DOCUMENTED + DRY-RUN DONE.** The §4.3 checklist was exercised as a dated **tabletop dry-run** against the populated register (§4.5, 2026-07-24), covering **100%** of systems with no gap. The first *real* run occurs on the first departure (single operator — none yet).
- **Access register — POPULATED + FIRST REVIEW DONE.** `ACCESS_REGISTER_TEMPLATE.md` is populated with a dated first review (2026-07-24); the HR1/HR3 dependency is satisfied.
- **Restricted HR file — CONFIRMED off-git.** WWCC / screening detail lives in Nic's encrypted local store (password manager / encrypted disk), backed up off Git; no PII in the repo.
- **Remaining — Nic's signature.** The substantive HR1/HR2/HR3 evidence now exists; the only open item is Nic countersigning this pack, the training record, and the register.